

NT230

CƠ CHẾ HOẠT ĐỘNG CỦA MÃ ĐỘC

GV: TS. Phan Thế Duy

Trường Đại học Công nghệ Thông tin
Đại học Quốc gia Thành phố Hồ Chí Minh

BUỔI 04 · WORM VÀ MÔ HÌNH LAN TRUYỀN





Buổi 04

Worm và mô hình lan truyền

Câu hỏi xuyên suốt

Worm tìm mục tiêu, xâm nhập và tạo ra các nút lan truyền mới như thế nào? CVE, USB và SSH yếu đóng vai trò gì?

- 100 phút; dùng hình ảnh báo cáo, lưu đồ và mô phỏng bằng thẻ nút.
- Đầu ra: lưu đồ lan truyền, phân tích đồ thị và giới hạn của mô hình.

Nội dung chính

- 1 Bối cảnh và mục tiêu
- 2 Khái niệm và chuỗi lan truyền
- 3 Nguồn lây nhiễm và lỗ hổng
- 4 Ví dụ thực tế gần đây
- 5 Mô hình mạng và phân đoạn
- 6 Cửng cố mở rộng
- 7 Mô phỏng, phân tích và Exit Ticket

1

Bối cảnh và mục tiêu

Câu hỏi trọng tâm

Vì sao một máy bị nhiễm có thể trở thành điểm phát tán cho nhiều máy khác?

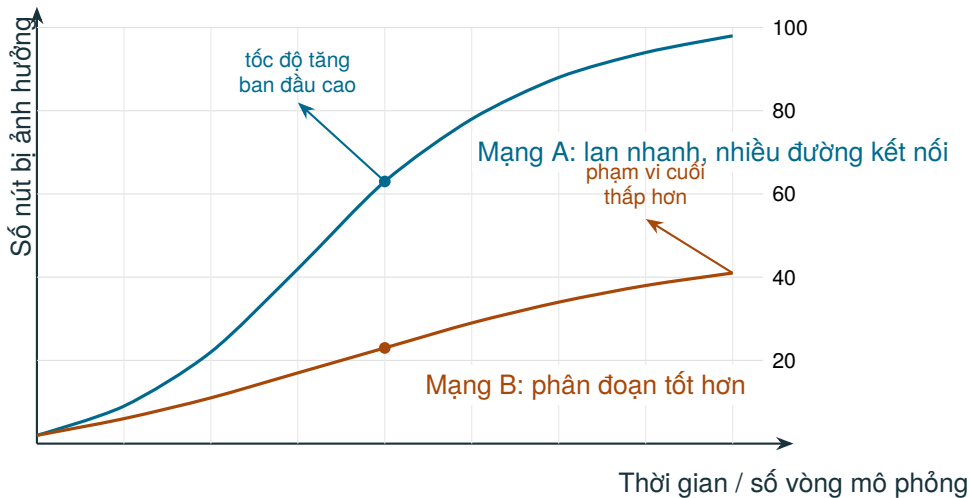
Mục tiêu học tập

- Phân biệt virus và worm theo cơ chế lan truyền.
- Mô tả chuỗi tìm mục tiêu → tiếp cận → khai thác/truyền → kích hoạt → lặp lại.
- Giải thích CVE là điểm yếu bị khai thác, không phải bản thân worm.
- Phân tích tác động của phân đoạn mạng trên đồ thị.

Tiêu chí thành công

Đọc được lưu đồ, xác định điểm xâm nhập và nêu một giới hạn của kết luận.

Gợi mở: hai đường cong



Câu hỏi xuyên suốt

Câu hỏi

Worm tìm mục tiêu, xâm nhập và tạo ra các nút lan truyền mới như thế nào?

- Ta quan sát được những gì?
- Điều gì chỉ là suy luận?
- Có thể cắt chuỗi ở đâu?

Bản đồ bài học



- Phần 2: khái niệm và lưu đồ.
- Phần 3: nguồn lây và CVE.
- Phần 4: Raspberry Robin, P2PInfect, FritzFrog.
- Phần 5: đồ thị, phân đoạn và mô phỏng.

Từ “lây nhiễm” đến “lan truyền”

Lây nhiễm

Một mục tiêu chuyển trạng thái.

Lan truyền

Một chuỗi nhiều mục tiêu theo thời gian.

Điểm nhấn

Phân tích worm cần nhìn cả nút, cạnh kết nối và thứ tự thời gian.

Kiến thức nền

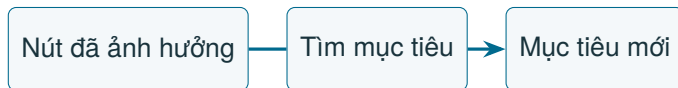
Cá nhân → cặp đôi · 1 phút

Phân loại bốn hành vi: sửa tệp, quét địa chỉ, mở tệp, kết nối sang máy khác. Hành vi nào gợi ý virus? Hành vi nào gợi ý worm?

Sản phẩm

Một bảng phân loại kèm lý do, không cần gọi tên mẫu mã độc.

Đường đi của một nút mới



- Một cạnh không đồng nghĩa khai thác thành công.
- Cần điều kiện truy cập, dịch vụ hoặc vật mang phù hợp.

Kiểm tra nhanh: đúng hay chưa đủ?

Nhận định

“Một máy có dịch vụ mở là chắc chắn đã bị worm lây nhiễm.”

- 1 Nhận định đúng hay chưa đủ?
- 2 Cần thêm loại bằng chứng nào?

Kiểm tra nhanh: đúng hay chưa đủ?

Nhận định

“Một máy có dịch vụ mở là chắc chắn đã bị worm lây nhiễm.”

- 1 Nhận định đúng hay chưa đủ?
- 2 Cần thêm loại bằng chứng nào?

Đáp án cốt lõi

Chưa đủ. Cần bằng chứng kết nối, khai thác/thực thi hoặc thay đổi trạng thái.

Bản đồ bằng chứng

Câu hỏi	Nguồn bằng chứng	Nguy cơ nhầm lẫn
Mục tiêu ở đâu?	DNS, IP, log kết nối	Địa chỉ quét không chứng minh xâm nhập
Điều gì xảy ra? Nút mới nào?	Process, service, event log Timeline, trạng thái host	Log thiếu hoặc lệch thời gian Trùng sự kiện

Tóm tắt phần 1

- Worm được hiểu qua chuỗi lan truyền, không chỉ qua tên mẫu.
- Phân tích cần tách quan sát, suy luận và điều chưa biết.
- Đồ thị mạng giúp biến câu chuyện thành mô hình có thể kiểm tra.

Cầu nối

Tiếp theo: virus và worm khác nhau ở đâu, và chuỗi lan truyền gồm những bước nào?

2

Khái niệm và chuỗi lan truyền

Câu hỏi trọng tâm

Một worm không chỉ “nhân bản”; nó tạo ra chuỗi tìm mục tiêu, xâm nhập và tiếp tục phát tán.

Virus và worm

Virus

- Gắn vào tệp hoặc vật chủ.
- Thường cần tệp được mở/chạy.
- Lan theo vật mang hoặc chia sẻ.

Worm

- Tự tìm mục tiêu qua kết nối.
- Có thể tự khởi động chuỗi.
- Nút mới tiếp tục phát tán.

Định nghĩa và ảnh hưởng

Worm là chương trình có khả năng tự tìm, tự truyền và tự kích hoạt trên các mục tiêu mới mà không cần gắn vào một tệp vật chủ cụ thể.

Vì vậy, worm có thể lan nhanh, tạo nhiều kết nối bất thường, tiêu thụ tài nguyên và mở rộng phạm vi ảnh hưởng theo số nút bị nhiễm.

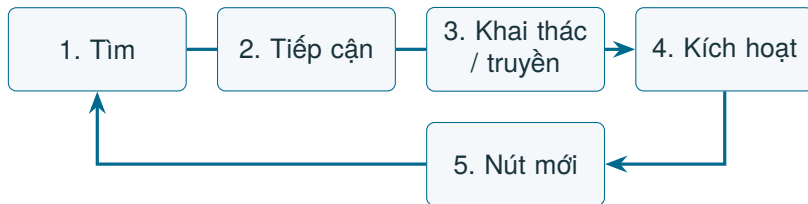
Phản ví dụ: không phải mọi lan truyền đều là worm

- Người dùng gửi thủ công một tệp độc hại: có lan truyền, nhưng chưa đủ để gọi là worm.
- Một máy chủ bị cập nhật quản trị tập trung: có nhiều máy thay đổi, nhưng không nhất thiết là tự lan truyền.
- Một worm cần cơ chế tự tìm hoặc tự tiếp tục trên các mục tiêu.

Câu hỏi

Yếu tố “tự động” nằm ở bước nào?

Lưu đồ 5 bước



Tìm

Quét hoặc chọn mục tiêu phù hợp.

Tiếp cận

Kết nối qua mạng, tài khoản hoặc vật mang.

Khai thác / truyền

Dùng lỗ hổng, quyền yếu hoặc sao chép.

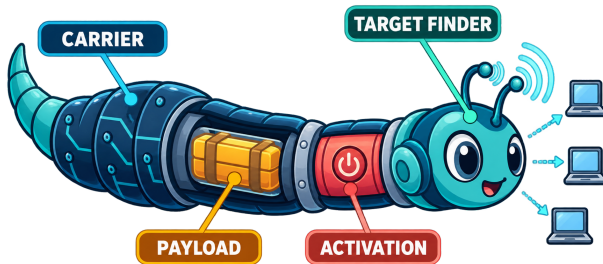
Kích hoạt

Mã được thực thi trên mục tiêu.

Nút mới

Mục tiêu trở thành nguồn phát tán tiếp theo.

Cấu trúc khái niệm của computer worm



Cách đọc hình

Target Finder/Discovery tìm mục tiêu; Carrier đưa worm đến mục tiêu; Activation làm worm hoạt động; Payload thực hiện hành vi sau khi được kích hoạt.

Kỹ thuật target discovery

Chủ động

- Quét địa chỉ hoặc dịch vụ.
- Chọn mục tiêu tuần tự/ngẫu nhiên.
- Ưu tiên mục tiêu trong mạng lân cận.

Thụ động

- Chờ nạn nhân liên hệ.
- Dựa trên email, web hoặc tệp chia sẻ.
- Ít tạo mẫu quét rõ ràng hơn.

Phân tích

Không thấy quét mạng không đồng nghĩa không có cơ chế tìm mục tiêu.

Các kiểu scanning

Tuần tự	Thử các địa chỉ theo một thứ tự xác định.
Ngẫu nhiên	Chọn địa chỉ rải rác để mở rộng phạm vi.
Ưu tiên cục bộ	Tập trung vào máy cùng mạng, hệ điều hành hoặc dịch vụ.
Phân chia không gian	Nhiều nút chia sẻ vùng quét để giảm trùng lặp.

Dấu vết

Tần suất, thứ tự và phạm vi kết nối có thể gợi ý cách worm tổ chức việc quét.

Bước 1: tìm mục tiêu

- Worm xác định “điểm tiếp theo” có khả năng kết nối hoặc lây nhiễm.
- Mục tiêu có thể là địa chỉ mạng, dịch vụ, tài khoản, thiết bị rời hoặc tệp chia sẻ.
- Cách chọn có thể tuần tự, ngẫu nhiên hoặc dựa trên thông tin đã thu thập.

Dấu vết gợi ý

Nhiều kết nối lặp lại, phân bố địa chỉ bất thường hoặc truy vấn dịch vụ theo cùng một mẫu.

Lưu ý

Tìm thấy mục tiêu chỉ cho thấy hoạt động trình sát; chưa chứng minh mục tiêu đã bị ảnh hưởng.

Bước 2: tiếp cận

USB

Vật mang
Thiết bị được gắn vào máy.

SSH

Phiên đăng nhập
Dịch vụ cho phép kết nối từ xa.

Dịch vụ

Kết nối mạng
Ứng dụng nhận yêu cầu từ bên ngoài.

Định nghĩa

Carrier / Delivery mechanism: cơ chế truyền worm qua một kênh hoặc vật mang đến mục tiêu.

Ý nghĩa phân tích

Mỗi đường vào tạo một loại dấu vết khác nhau: sự kiện thiết bị, log xác thực hoặc lưu lượng dịch vụ.

Carrier: worm truyền bản thân như thế nào?

Self-carried

Mã được truyền trực tiếp trong quá trình lây nhiễm.

Second channel

Dùng kênh phụ để tải phần còn lại.

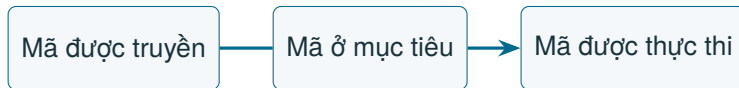
Embedded

Mã gắn trong luồng giao tiếp bình thường.

Điểm phân tích

Carrier trả lời câu hỏi: “Mã đi từ nút nguồn đến nút đích bằng đường nào?”

Carrier không đồng nghĩa activation



- Tập hoặc dữ liệu đã đến nơi chưa chứng minh mã đã chạy.
- Cần tách bằng chứng truyền/tải khỏi bằng chứng thực thi.

Bước 3: khai thác hoặc truyền

- Khai thác lỗ hổng của dịch vụ hoặc điều kiện cấu hình yếu.
- Sử dụng thông tin xác thực không đủ mạnh để mở phiên truy cập.
- Sao chép qua thiết bị, tệp chia sẻ hoặc kênh kết nối được phép.

Cần phân biệt

“Có yêu cầu bất thường” là dấu hiệu của nỗ lực tiếp cận; cần thêm bằng chứng thực thi hoặc thay đổi trạng thái để kết luận khai thác thành công.

An toàn

Chỉ mô tả cơ chế và dấu vết; không trình bày lệnh hoặc quy trình khai thác.

Các cơ chế kích hoạt

Human activation **Activity-based**

Người dùng mở tệp hoặc thực hiện hành động.
Kích hoạt sau đăng nhập, khởi động lại hoặc hoạt động thường ngày.

Self activation

Dịch vụ đang chạy tự xử lý yêu cầu hoặc điều kiện khai thác.

Câu hỏi điều tra

Điều kiện nào xảy ra ngay trước process, service hoặc thay đổi trạng thái mới?

Payload: worm mang theo gì?

- Payload là phần hành vi hoặc thành phần phục vụ mục tiêu sau khi được kích hoạt.
- Có thể tải thêm thành phần, duy trì kiểm soát, gửi dữ liệu hoặc gây gián đoạn.
- Payload không phải toàn bộ worm; nó là phần được thực hiện sau khi đến mục tiêu.

Phạm vi bài học

Chỉ phân tích vai trò và dấu vết; không mô tả mã hoặc quy trình gây hại.

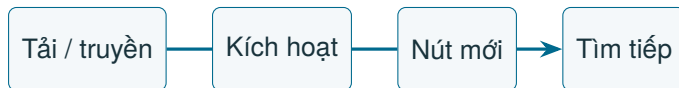
Tải payload nhiều giai đoạn (multi-stage payload)



Dấu vết

Kết nối phát sinh sau thực thi đầu tiên, tệp/module mới và quan hệ thời gian giữa loader với thành phần sau.

Bước 4–5: kích hoạt và lặp lại



- Tập hoặc dữ liệu được đưa tới mục tiêu chưa đồng nghĩa đã được thực thi.
- Khi kích hoạt thành công, mục tiêu chuyển thành một nút mới trong chuỗi.
- Nút mới có thể tiếp tục tìm mục tiêu khác, tạo vòng lặp lan truyền.

Điểm kiểm chứng

Cần nối sự kiện tải/truyền với process, service, log hoặc thay đổi trạng thái tương ứng.

Kiểm tra nhanh 1

- ❶ Vì sao quét cổng không đồng nghĩa lây nhiễm?
- ❷ Cần phân biệt “truyền” và “kích hoạt” như thế nào?

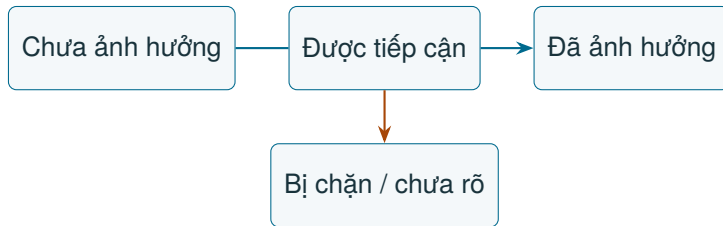
Kiểm tra nhanh 1

- ❶ Vì sao quét cổng không đồng nghĩa lây nhiễm?
- ❷ Cần phân biệt “truyền” và “kích hoạt” như thế nào?

Đáp án cốt lõi

Quét chỉ cho thấy tìm mục tiêu; truyền/tải và thực thi là các mắt xích cần bằng chứng riêng.

Sơ đồ trạng thái của một nút



Mục tiêu phân tích

Không ép mọi quan sát vào hai trạng thái “sạch/bị nhiễm”; giữ riêng trạng thái chưa rõ.

Tóm tắt phần 2

- Chuỗi worm gồm tìm, tiếp cận, khai thác/truyền, kích hoạt và lặp lại.
- Mỗi bước có dấu vết và khả năng thất bại khác nhau.
- Trạng thái “chưa rõ” giúp tránh kết luận quá mạnh.

3

Nguồn lây nhiễm và lỗ hổng

Câu hỏi trọng tâm

Lỗ hổng (vulnerability) là tên gọi chung của điểm yếu có thể bị lợi dụng; CVE chỉ là một dạng mã định danh khi lỗ hổng đã được công bố.

Ba nhóm đường vào

Thiết bị / tệp

USB
tệp chia sẻ
ổ mạng

Vật mang đưa mã hoặc tệp đến một máy khác.

Tài khoản / dịch vụ

SSH
mật khẩu yếu
dịch vụ mở

Quyền truy cập hoặc cấu hình cho phép worm tiếp cận.

Lỗ hổng

vulnerability
CVE nếu đã công bố
dịch vụ lỗi

Điểm yếu có thể bị lợi dụng để thực thi hoặc truyền mã.

Phân biệt

“Lỗ hổng” là khái niệm rộng; CVE là mã tham chiếu của một số lỗ hổng đã được ghi nhận.

Lỗ hổng (vulnerability) là gì?

- Là điểm yếu trong phần mềm, dịch vụ, cấu hình, thiết kế hoặc quy trình vận hành.
- Điểm yếu có thể cho phép truy cập trái phép, thực thi mã, vượt quyền hoặc truyền dữ liệu.
- Không phải mọi lỗ hổng đều đã có mã CVE, đã được công bố hoặc đã được phân loại đầy đủ.

Cách dùng trong bài

Dùng “lỗ hổng” khi nói chung; dùng “CVE” khi có mã định danh và nguồn tham chiếu cụ thể.

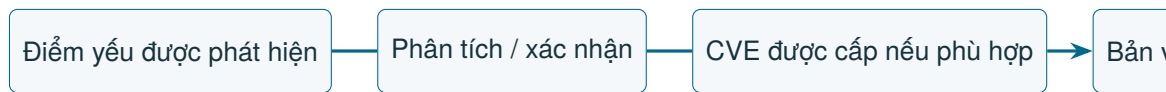
CVE là gì trong mối quan hệ đó?

- CVE là mã định danh chuẩn cho một lỗ hổng được ghi nhận trong danh mục công khai.
- CVE giúp liên kết mô tả, phiên bản ảnh hưởng, thời điểm công bố và thông tin khắc phục.
- Có CVE không có nghĩa hệ thống đã bị khai thác; tác động còn phụ thuộc phơi lộ, cấu hình, quyền và điều kiện mạng.

Cách nói chính xác

“Worm khai thác một lỗ hổng của dịch vụ X; lỗ hổng này có thể được tham chiếu bằng CVE-Y nếu đã được công bố.”

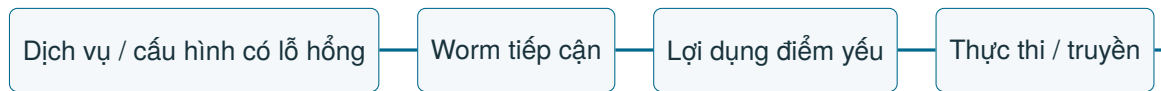
Lỗ hổng có thể tồn tại trước khi có CVE



Thông điệp

CVE là nhãn tham chiếu trong vòng đời xử lý; nó không phải điều kiện bắt buộc để một worm lợi dụng điểm yếu.

Lỗ hổng trong chuỗi lây nhiễm



Điểm kiểm soát

Vá hoặc cấu hình lại điểm yếu; giảm phơi lộ; giới hạn quyền; phân đoạn; giám sát hành vi.

Lỗ hổng không đồng nghĩa lây nhiễm

Tình huống

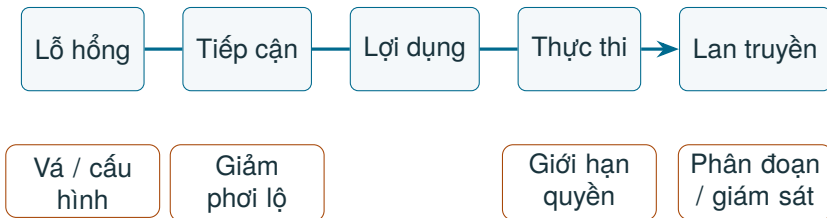
Một máy chạy phiên bản dịch vụ có điểm yếu, nhưng nằm sau phân đoạn mạng và chưa có kết nối đáng ngờ.

- Có điều kiện dễ tổn thương hoặc rủi ro tiềm tàng.
- Chưa đủ bằng chứng worm đã tiếp cận hay lợi dụng thành công.
- Cần kiểm tra log kết nối, thời gian, process/service và thay đổi trạng thái.

Mức kết luận

“Có lỗ hổng” khác với “đã bị khai thác”, và “đã bị khai thác” khác với “đã trở thành nút lan truyền”.

Cắt chuỗi ở đâu?



Ý nghĩa

Một biện pháp có thể làm giảm một mắt xích nhưng không nhất thiết loại bỏ toàn bộ chuỗi.

Dấu vết theo từng đường vào

Đường vào	Dấu vết gợi ý	Cần tránh suy diễn
USB / tệp	Sự kiện thiết bị, tệp mới, thời gian kết nối	Thiết bị xuất hiện không chứng minh tệp đã chạy
SSH / dịch vụ	Đăng nhập, IP nguồn, process con, request	Đăng nhập hợp lệ chưa chắc là worm
Lỗ hổng chung	Phiên bản, cấu hình, yêu cầu bất thường, thực thi con	Có điểm yếu không chứng minh đã khai thác
CVE cụ thể	Mã tham chiếu, phiên bản ảnh hưởng, dấu vết phù hợp	Có CVE không chứng minh hệ thống bị tác động

Đọc một kết luận theo ba tầng

- 1 **Điều kiện:** hệ thống có lỗ hổng hoặc đường vào phù hợp.
- 2 **Sự kiện:** worm tiếp cận, truyền mã hoặc tạo process/service.
- 3 **Tác động:** mục tiêu bị ảnh hưởng và có thể trở thành nút lan truyền mới.

Nguyên tắc

Không nhảy từ tầng điều kiện sang tầng tác động nếu thiếu bằng chứng trung gian.

Sai lầm thuật ngữ thường gặp

- Gọi mọi lỗ hổng là CVE, dù chưa có mã định danh công khai.
- Gọi CVE là malware hoặc là tác nhân gây lây nhiễm.
- Gọi mọi kết nối quét là lây nhiễm.
- Gọi mọi dịch vụ mở là đã bị xâm nhập.
- Bỏ qua trạng thái “chưa đủ dữ liệu”.

Nguyên tắc

Dùng thuật ngữ rộng khi chưa có định danh cụ thể; chỉ nêu CVE khi có nguồn và phạm vi phù hợp.

Tóm tắt phần 3

- Lỗ hổng (vulnerability) là tên gọi chung cho điểm yếu có thể bị lợi dụng.
- CVE là mã định danh của một số lỗ hổng đã được ghi nhận, không phải tên gọi chung cho mọi điểm yếu.
- Có lỗ hổng không đồng nghĩa đã bị khai thác hoặc đã lây nhiễm.
- Phân tích cần nói điều kiện, sự kiện, tác động và nguồn bằng chứng.
- Phòng thủ có thể cắt chuỗi trước, trong hoặc sau khi worm thực thi.

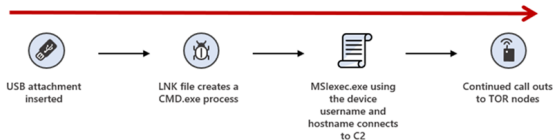
4

Ví dụ thực tế gần đây

Câu hỏi trọng tâm

Nhìn worm qua đường đi, nút mới và dấu vết; không học theo mã khai thác.

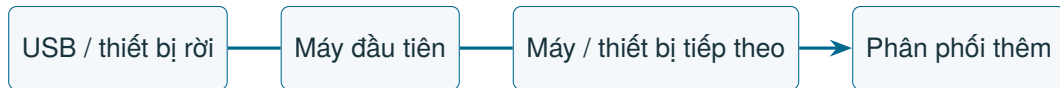
Raspberry Robin: bồi cảnh



- Được mô tả là malware có khả năng “wormable”.
- Có liên hệ với nhiều phương thức lây nhiễm, trong đó có USB.
- Chuỗi lây nhiễm có thể bao gồm vật mang, kích hoạt, tải thêm thành phần và kết nối tiếp theo.

Nguồn: Microsoft Threat Intelligence, 2022; CISA/FBI/MS-ISAC, 2023

Raspberry Robin: lưu đồ minh họa



Dự đoán · 3 phút

Nếu chặn USB nhưng vẫn cho phép tệp chia sẻ, mất xích nào còn tồn tại?

Raspberry Robin: quan sát và suy luận

Quan sát	Suy luận có thể	Cần bổ sung
Thiết bị USB xuất hiện	Có đường vào tiềm năng	Tệp nào được tạo/chạy?
Nhiều máy có artefact giống nhau	Có thể có vật mang chung	Timeline và hash
Payload khác xuất hiện	Có thể là giai đoạn sau	Quan hệ tiến trình

P2PInfect: bối cảnh

```
CreateFileW ("C:\Users\wlab\Desktop\data\sample_honeyrust\linux", GENERIC_R  
CreateFileW ("C:\Users\wlab\Desktop\data\sample_honeyrust\linux_sign", GENE  
CreateFileW ("C:\Users\wlab\Desktop\data\sample_honeyrust\miner", GENERIC_F  
CreateFileW ("C:\Users\wlab\Desktop\data\sample_honeyrust\miner_sign", GENE  
CreateFileW ("C:\Users\wlab\Desktop\data\sample_honeyrust\winminer", GENER  
CreateFileW ("C:\Users\wlab\Desktop\data\sample_honeyrust\winminer_sign", G  
CreateFileW ("C:\Users\wlab\Desktop\data\sample_honeyrust\windows", GENER  
CreateFileW ("C:\Users\wlab\Desktop\data\sample_honeyrust\windows_sign", G
```

- Được Unit 42 phát hiện vào tháng 7/2023.
- Là worm tự sao chép sử dụng mạng ngang hàng.
- Nhắm đến các Redis instance bị phơi lộ hoặc dễ tổn thương.
- Mỗi nút bị ảnh hưởng có thể tham gia trao đổi thông tin peer, tải thêm nhiều sample mã độc khác.
- Quá trình quét Redis và cập nhật danh sách peer là hai hành vi cần phân biệt.

Nguồn: Unit 42, Palo Alto Networks, 2023; Figure 5 và Figure 7

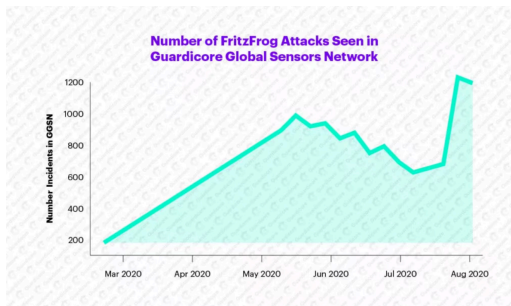
P2PInfect: vì sao P2P đáng chú ý?

- Không phụ thuộc duy nhất vào một máy chủ điều khiển.
- Nút bị ảnh hưởng có thể trao đổi thông tin mục tiêu.
- Đường đi lan truyền có thể thay đổi theo trạng thái mạng.

Câu hỏi

Phân đoạn một vùng có làm các vùng khác chắc chắn an toàn không?

FritzFrog: bối cảnh

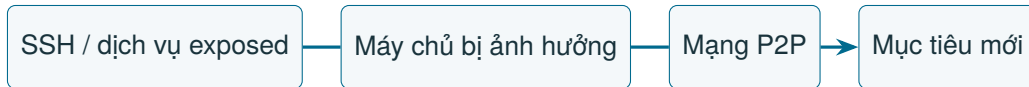


Ảnh hưởng của FritzFrog năm 2020.

Nguồn: Akamai Security Intelligence Group, 2024, Figure 4

- Nhắm đến máy chủ Linux có dịch vụ SSH exposed.
- Các máy bị ảnh hưởng có thể trao đổi thông tin mục tiêu qua mạng P2P.
- Biến thể được Akamai phân tích năm 2024 bổ sung đường vào qua Log4Shell.
- Sau khi thực thi, máy nạn nhân có thể trở thành một nút FritzFrog mới.

FritzFrog: nối SSH, CVE và P2P



Điểm học

Một họ worm có thể tiến hóa đường vào nhưng giữ logic tự tiếp tục lan truyền.

So sánh ba ví dụ

Mẫu	Đường vào	Kiểu mạng / mục tiêu	Bài học
Raspberry Robin P2PInfect	USB / thiết bị rời Dịch vụ Redis/cloud	Máy trạm P2P, đa nền tảng	Kiểm soát vật mang Nút nhiễm hỗ trợ lan truyền
FritzFrog	SSH/CVE	Máy chủ Linux, P2P	Dịch vụ exposed tăng bề mặt

Hoạt động: điền mắt xích còn thiếu

Nhóm · 5 phút

Mỗi nhóm nhận một ví dụ. Điền vào bốn ô: mục tiêu, đường vào, trạng thái nút mới, cơ chế tiếp tục.

Sản phẩm

Một lưu đồ bốn ô và một câu “chưa thể kết luận”.

Tóm tắt phần 4

- Ví dụ thực tế giúp nối khái niệm với đường đi và dấu vết.
- P2P làm thay đổi cách nhìn về “trung tâm điều khiển”.
- Hình ảnh báo cáo cần đi kèm chú thích nguồn và giới hạn diễn giải.

5

Mô hình mạng và phân đoạn

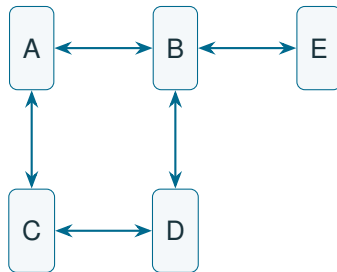
Câu hỏi trọng tâm

Mô hình hóa giúp thay một biến, quan sát đường cong và tránh kết luận vượt dữ liệu.

Mạng được mô hình hóa như thế nào?

- Nút: máy trạm, máy chủ, container hoặc dịch vụ.
- Cạnh: đường kết nối, quyền truy cập hoặc khả năng giao tiếp.
- Trạng thái: chưa ảnh hưởng, tiếp cận, đã ảnh hưởng, bị cô lập.
- Thời gian: mỗi vòng mô phỏng là một khoảng quy ước.

Một đồ thị nhỏ



Câu hỏi

Nếu A là nút khởi đầu, nút nào có thể được tiếp cận ở vòng 1?

Đường đi và số nút

Đường đi ngắn

Ít bước hơn
lan truyền nhanh hơn

Nhiều cạnh

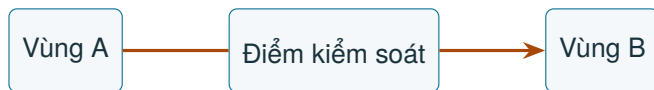
Nhiều lựa chọn
khó cô lập hơn

Không đồng nhất

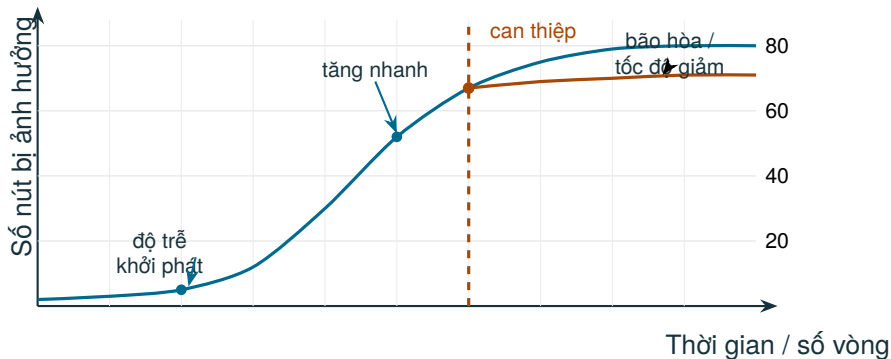
Nhiều cạnh chỉ tạo khả năng tiếp cận; còn cần điều kiện khai thác/truyền.

Phân đoạn mạng là gì?

- Chia mạng thành các vùng có quyền và đường đi khác nhau.
- Giảm số cạnh hoặc làm cạnh cần qua điểm kiểm soát.
- Không tự vá lỗi hỏng và không xóa trạng thái đã bị ảnh hưởng.



Độc đường cong để đánh giá can thiệp



- **Độ trễ khởi phát:** mất bao lâu trước khi số nút tăng rõ rệt?
- **Tăng nhanh:** mạng mở rộng lan truyền ở tốc độ nào?
- **Sau can thiệp:** độ dốc có giảm và đường cong có tiến tới bão hòa sớm hơn không?

Nhiều và giả định

- Luật chọn mục tiêu có thể thay đổi kết quả.
- Seed hoặc thứ tự chạy có thể tạo biến thiên.
- Đồ thị nhỏ không đại diện cho mạng thực.
- Một kết quả mô phỏng không đủ để khẳng định nhân quả ngoài phạm vi.

Câu hỏi

Giả định nào cần ghi trên slide để người khác tái lập?

CVE và phân đoạn: hai biện pháp khác nhau

Biện pháp	Tác động chính	Không giải quyết trực tiếp
Vá CVE	Giảm điều kiện khai thác	Đường lây khác
Phân đoạn	Giảm khả năng tiếp cận	Lỗ hổng trên nút
Giới hạn quyền	Giảm tác động sau xâm nhập	Quét ban đầu

Kiểm tra nhanh 3

- 1 Phân đoạn mạng chủ yếu thay đổi nút hay cạnh?
- 2 Vì sao một nút chưa bị ảnh hưởng không đồng nghĩa “an toàn tuyệt đối”?
- 3 Khi nào đường cong hai cấu hình không thể so sánh công bằng?

Kiểm tra nhanh 3

- 1 Phân đoạn mạng chủ yếu thay đổi nút hay cạnh?
- 2 Vì sao một nút chưa bị ảnh hưởng không đồng nghĩa “an toàn tuyệt đối”?
- 3 Khi nào đường cong hai cấu hình không thể so sánh công bằng?

Đáp án cốt lõi

Phân đoạn chủ yếu làm giảm/kiểm soát cạnh; còn cần xem lỗ hổng và thời gian; so sánh sai khi nhiều biến cùng thay đổi.

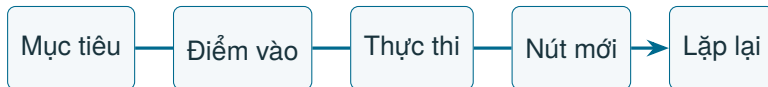
Tóm tắt phần 5

- Đồ thị gồm nút, cạnh, trạng thái và thời gian.
- Phân đoạn làm giảm khả năng tiếp cận, không đồng nghĩa miễn nhiễm.
- Mọi đường cong cần đi kèm giả định và giới hạn.

Bảng tự kiểm tra trước khi kết luận

Tôi đã xác định mục tiêu?	Địa chỉ, dịch vụ hoặc thiết bị cụ thể.
Tôi có bằng chứng thực thi?	Không đồng nhất quét với lây nhiễm.
Tôi đã ghi giả định?	Thời gian, luật mô phỏng, phân đoạn.
Tôi đã nêu giới hạn?	Điều gì còn chưa biết?

Một câu chuyện hoàn chỉnh



Bài nói 30 giây

Mỗi sinh viên giải thích một mũi tên bằng một bằng chứng hoặc một giả định.

Phản biện kết luận quá mạnh

Kết luận

“Mạng B an toàn vì sau ba vòng chỉ có hai nút bị ảnh hưởng.”

Trao đổi cặp · 3 phút

Viết lại kết luận thận trọng hơn, giữ lại điều quan sát được và thêm điều kiện áp dụng.

Thông điệp cuối cùng



Nhớ

Phân tích tốt không chỉ trả lời “worm làm gì”, mà còn nói rõ “ta biết bằng cách nào” và “chưa biết điều gì”.

Chuẩn bị chuyển sang bài tiếp theo

- Giữ lại ba từ khóa: mục tiêu, cạnh kết nối, trạng thái.
- Ôn lại sự khác nhau giữa quét, khai thác và kích hoạt.
- Khi xem một báo cáo worm, hãy tìm lưu đồ trước khi đọc chi tiết kỹ thuật.

6

Mô phỏng, phân tích và Exit Ticket

Câu hỏi trọng tâm

Từ thẻ nút đến đồ thị: thay một biến, ghi bằng chứng và giải thích kết quả.

Hoạt động nhóm: mô phỏng bằng thẻ

Nhóm 3–4 người · 15 phút

Nhận đồ thị 10 nút và một kịch bản: USB, SSH hoặc CVE. (1) đánh dấu nút đầu; (2) mô phỏng 3 vòng; (3) ghi số nút; (4) thay đổi duy nhất mức phân đoạn.

An toàn

Chỉ mô phỏng trạng thái trên giấy; không sử dụng mã độc, lệnh khai thác hoặc mạng thật.

Vai trò trong nhóm

- Người điều phối: đọc luật mô phỏng.
- Người ghi chép: ghi trạng thái và vòng.
- Người kiểm chứng: kiểm tra điều kiện cạnh.
- Người trình bày: giải thích một thay đổi.

Mục tiêu

Mọi thành viên đều phải có thể giải thích ít nhất một bước chuyển trạng thái.

Phiếu ghi nhận

Vòng	Cấu hình A	Cấu hình B	Ghi chú
0	Nút đầu	Nút đầu	Điều kiện xuất phát
1	Số nút	Số nút	Cạnh được dùng
2	Số nút	Số nút	Vùng bị cô lập
3	Số nút	Số nút	Giới hạn quan sát

Debrief: kết quả không tự nói nguyên nhân

- Đường cong tăng nhanh có thể do nhiều cạnh hoặc luật chọn mục tiêu.
- Một nút chưa đổi trạng thái chưa chứng minh an toàn tuyệt đối.
- So sánh hợp lệ cần giữ nguyên mọi yếu tố ngoài biến xét.

Tóm tắt toàn bài

- Worm tạo chuỗi tìm mục tiêu, tiếp cận, khai thác/truyền, kích hoạt và lặp lại.
- CVE là điểm yếu được khai thác, không phải bản thân worm.
- Raspberry Robin, P2PInfect và FritzFrog minh họa các đường lây khác nhau.
- P2P làm nút bị ảnh hưởng có thể tiếp tục hỗ trợ lan truyền.
- Phân đoạn mạng làm giảm khả năng tiếp cận nhưng không thay thế vá lỗi.

Exit Ticket

Cá nhân · 5 phút

Trả lời mỗi câu trong 2–3 dòng:

1. Viết lại chuỗi lan truyền của worm bằng ít nhất bốn bước.
2. CVE đóng vai trò gì trong chuỗi lây nhiễm? Vì sao không nên gọi CVE là nguồn lây?
3. Phân đoạn mạng làm thay đổi điều gì, và một giới hạn của kết luận từ đồ thị là gì?

Gợi ý đáp án Exit Ticket

- 1 Tìm mục tiêu → tiếp cận → khai thác/truyền → kích hoạt → nút mới tiếp tục.
- 2 CVE là lỗ hổng/điểm vào; worm là tác nhân thực hiện và phát tán.
- 3 Phân đoạn làm giảm/kiểm soát cạnh; đồ thị chỉ đúng trong phạm vi giả định.

Tài liệu tham khảo I

-  CISA, FBI, MS-ISAC. *Increased Truebot Activity Infects U.S. and Canada-Based Networks*, 2023.
-  Unit 42. *P2PInfect: The Rusty Peer-to-Peer Self-Replicating Worm*, 2023.
-  Akamai. *Frog4Shell — FritzFrog Botnet Adds One-Days to Its Arsenal*, 2024.
-  MITRE ATT&CK. *T1046 Network Service Scanning; T1190 Exploit Public-Facing Application*.
-  William Stallings, Lawrie Brown. *Computer Security: Principles and Practice*.